

Scruple — Generator Product Conformance Program submission (GPSA v3)

Intake record ID: 019f5856-bff8-7f57-a879-80594a6fb3fe

Bundle: scruple-c2pa-conformance-2026-07-30.zip

Filed at **Assurance Level 2** against the C2PA Generator Product Security Requirements v0.1. Implicit Level 1 conformance retained.

This is a full resubmission addressing the 2026-08-04 GPSA Reviewer report:

1. **6.3.1 TOE boundary** — clarified assertion provenance boundary; third-party assertions are placed in gathered_assertions and never in created_assertions. Enforced at the API boundary by services/c2pa-signer/assertion_partition.py (10 unit tests) and documented in GPSA §C.1.3 and §C.2.4.
2. **6.3.2 + 6.4.2 OS patch recency** — added a real per-sign OS-patch-date extractor (services/c2pa-signer/os_patch_check.py, 13 unit tests) that reads the running instance's dnf/apt package history and refuses to sign if the OS security patch date is > 90 days old. The extracted date is bound into every signed manifest via the ai.scruple.signer-runtime.v1 assertion so verifiers can independently confirm patch recency at signing time. Documented in GPSA §C.2.3 (new §C.2.3.0) and §C.2.4. The 60-day CVM fleet rotation remains as the operational belt-and-braces that keeps the per-sign check trivially satisfied.
3. **Samples bundle restructured** per your specification — Part-1-Media-Samples/generate/ for manifests of asserted generate media types, Part-1-Media-Samples/validate/raw/ and Part-1-Media-Samples/validate/ingested/ for the ingest examples. All .json sidecars removed. Redundant Part-2-Runtime-Assertion-Sample removed — the runtime assertion is now embedded in every Part-1 signed asset per fix #2 above.

The GPSA v3 stands on its own — it is the complete, current security architecture for the Scruple Signer, incorporating all changes above. Any prior architecture document, delta, or update on file for this Intake ID is superseded by this submission.

Confirmations

- **Target assurance:** Level 2 (implicit Level 1 conformance).
- **Product name:** Scruple.
- **Product role:** Generator Product, Distributed implementation class.

What's in the bundle

```
scruple-c2pa-conformance-2026-07-30.zip
|--- security-architecture/
|   |--- 01-GPSA.md                <-- GPSA v3 (complete, standalone)
|   |--- runbooks/
|       |--- cvm-provision.md
|       |--- cert-enrollment.md
```

```

| | |--- customer-onboarding.md
| | \--- bootstrap/ <-- cloud-init YAML + ceremony scripts
| | \--- evidence/
| | |--- architecture-diagram.md
| | | \--- l2-evidence-2026-07-12T174954Z/ <-- SEV-SNP attestation bundle
|--- Part-1-Media-Samples/
| |--- generate/ <-- signed C2PA outputs, one per asserted generate M
| | \--- validate/
| | |--- raw/ <--
raw input files (asserted ingest MIMEs)
| | \--- ingested/ <-- post-ingest signed derivatives
|--- deploy_snapshot_oci-signer-rotation/ <-- Terraform + Function code for the Signer
|--- services_snapshot/c2pa-signer/ <-- Signer runtime source
| | includes NEW: os_patch_check.py + assertion_partition
|--- lib_snapshot/c2pa/ <-- TypeScript C2PA signer entry point
|--- external-c2pa-samples/ <-- Third-party C2PA samples used for cross-
implementation validation
|--- trust-validation-results/ <-- Per-sample validation reports
\--- 02-dev-root-ca.pem, 03-dev-signer-cert.pem <-- dev cert chain for sample verifi

```

Key points for first-pass review (v3 changes highlighted)

- **6.3.1 TOE boundary (NEW).** Every created_assertions entry on a Scruple-signed manifest is authored by code inside the attested Signer CVM TOE. Client-supplied labels are partitioned by assertion_partition.py: C2PA-standard + Scruple-namespaced labels land in created_assertions; explicit external-provenance labels (schema.org, IPTC, EXIF) land in gathered_assertions; unknown labels are rejected (fail-closed). Documented in GPSA §C.2.4.
- **6.3.2 + 6.4.2 OS patch recency (NEW).** The Signer extracts the actual OS security patch date from the running instance's package-manager history (dnf.rpm.log or apt/history.log) and refuses to sign if it is > 90 days old. The extracted date is bound into every signed manifest via ai.scruple.signer-runtime.v1 fields os_security_patch_date, os_security_patch_age_days, os_security_patch_source. A verifier can independently confirm patch recency by reading the signed manifest. Documented in GPSA new §C.2.3.0. The 60-day CVM fleet rotation is retained as belt-and-braces and documented in §C.2.3.0-b.
- **Confirmation of validate scope.** Scruple is NOT a capture-only product. Part-1-Media-Samples/validate/ingested/ exercises every asserted validate MIME end-to-end.
- **Implementation Class: Distributed.** Client → Application tier → Signer (AMD SEV-SNP Confidential VM fleet on OCI, ES256 private key inside a PKCS#11 HSM). Full architecture diagram in GPSA §C.1.4.
- **L2 §6.2.2 key confidentiality.** SEV-SNP attestation bundle attached; binds the C2PA signing key to a specific attested CVM. Independent verification via AMD's public VCEK chain.

- **L2 across all applicable objectives, self-assessed:** 0.2, 0.3, 0.4, 0.5, 0.6 all satisfy L2 per the shipped state. 0.1 (§6.1 automated cert enrollment) is not applicable because C2PA Trust List CA enrollment is manual by design.
- **Vulnerability disclosure.** SECURITY.md at the public repository root documents the coordinated-disclosure process, contact (scruple@docentechs.com), triage SLA (48 hours), and remediation timelines per GPSR §6.6 footnote.

Documented gaps

Two MIMEs cannot currently be signed by the c2pa-python 0.89 wrapper used by our sample producer (application/pdf, application/x-pytorch). Raw samples are provided in Part-1-Media-Samples/validate/raw/. Signed samples will follow when the wrapper exposes the feature. The underlying c2pa-rs supports both.

Sample validation

Every included signed sample independently verifies as validation_state=Valid via a fresh c2pa.Reader against the included development cert chain (02-dev-root-ca.pem and 03-dev-signer-cert.pem). Cross-implementation validation against a third-party C2PA sample set (in external-c2pa-samples/) has been run end-to-end by our reference validator; per-sample reports are at trust-validation-results/.

Reproducibility

The bundle producer, signer, validator, rotation Function, IAM policies, patch-recency extractor, assertion partition, CI workflows, and all tests are in the public repository at github.com/Docenttx/Scruple/. The specific commit corresponding to this submission is captured in security-architecture/evidence/README.md.